

■ SUBSIDY DROPOFF

Website & Product Audit — *subsidydropoff.com*

A full-depth, Fortune-500-standard review of front-end, back-end, design, UX, SEO, indexing, performance, accessibility, security, privacy, PWA, monetization readiness, and content depth — cross-referenced against the exact source tree Cloudflare Pages deploys from and against 20+ live competitors surfaced this session.

DOMAIN

subsidydropoff.com

AUDIT
DATE

**August
31,
2026**

PORTFOLIO

**Niche
Utility
Collection**



Overall Grade

Strong
engineering,
non-functional
distribution.
See §1.

Document Map

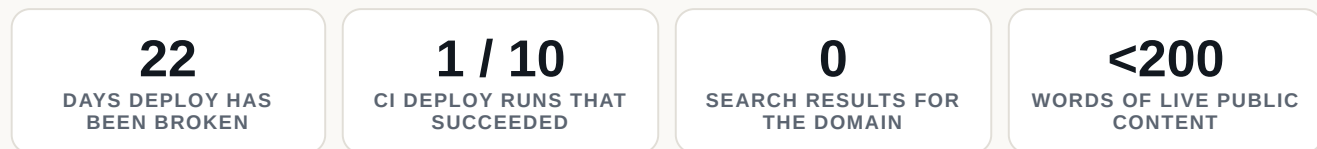
1 — Executive Summary & Overall Grade	D+
2 — Methodology & What This Audit Could and Could Not Verify	
3 — Grading Scale	
4 — Grade Summary (14 Dimensions)	
5 — Dimension-by-Dimension Findings	
6 — Strengths to Preserve	
7 — Technical Stack, Identified Precisely	
8 — Competitive Landscape (Condensed)	
9 — Portfolio-Context Notes	

Companion document: *Numbered Issues, Verbatim Fixes & 30-Day Plan* — every finding below is cross-referenced there by issue number, with ready-to-implement fix language for each.

Executive Summary

Subsidy Dropoff is architecturally one of the stronger tools in its niche: pure-function subsidy math shared verbatim between server and client, strict typed request validation, a zero-PII-by-construction privacy posture, and a close-to-best-practice security header set. None of that is currently reaching anyone reliably.

Three facts should be read together, because each compounds the others rather than standing alone:



The Cloudflare API token that authorizes production deploys has been invalid since 2026-08-10 — every one of the four scheduled weekly redeploys since has failed identically with `Authentication error [code: 10000]`, and the site has been frozen on its 2026-08-09 snapshot for three weeks with no working self-heal path. A second, independent bug — a CMS data endpoint that now returns a genuine HTTP 404 — is already queued behind the first: the moment the token is fixed, the very next deploy will ship with *zero* benchmark data unless that is fixed too. Meanwhile a live web search for the domain returns nothing at all — no indexed pages, no backlinks, no citations anywhere — and the entire public-facing content footprint is one page under 200 words, while roughly 1,000–1,150 words of genuinely well-written subject-matter explanation already sit finished inside README.md and an unshipped methodology page. The willingness and the capability to write authoritative content both already exist in this codebase; none of it is doing its job.

Layered underneath is a second, quieter problem: the repository maintains two complete front-end implementations — the plain HTML/CSS/JS shell that is actually deployed to the production domain, and a considerably richer Next.js/Tailwind rebuild that has not received a commit in 34 days. That second tree is not "abandoned" in the way its git history alone suggests: a native Vercel GitHub integration (confirmed via an automated deployment comment on this audit's own pull request) auto-builds and deploys it to preview URLs on every push, across two separately linked Vercel projects, entirely outside the repository's own committed CI configuration and undocumented anywhere in it. Neither Vercel project appears to hold the production custom domain — DNS for `subsidydropoff.com` resolves cleanly to Cloudflare, not Vercel — so this is a second, independent, continuously-succeeding deploy pipeline shipping a product nobody has pointed a real domain at or merged back into what is actually live. That split has already produced a live, user-facing bug on the domain that does matter (the site's own vanity redirects point at a page that doesn't exist in the deployed tree) and leaves the one CI type-check gate blind to the serverless handler that runs on every real request.

None of this is a verdict on the team's engineering ability — the opposite, in fact. It is a verdict on distribution and operational discipline. The fixes for the two most severe issues are, respectively, rotating one API token and updating one URL string. Document 2 sequences the full remediation as a 30-day plan; the first week is entirely about closing exactly these gaps.

Methodology & What This Audit Could Verify

This audit was conducted under a network-restricted sandbox: every direct HTTPS fetch to `subsidydropoff.com` — via `curl` and via an automated page-fetch tool — returned a blocked-egress error. A control fetch to a neutral domain (`example.com`) and to the Wayback Machine returned the identical block, confirming this is a session-wide restriction rather than anything specific to the target. As a direct consequence, **no live browser screenshot, no live response-header capture, no rendered Core Web Vitals measurement, and no live raw-HTML fetch could be produced for this audit.** Where a finding below depends on a claim that could only be settled by such a live check, it is marked explicitly and the recommended follow-up action is stated.

In place of a black-box crawl, this audit is built on four higher-precision, verifiable sources:

SOURCE	WHAT IT ESTABLISHES
Direct source inspection	The repository's checked-out HEAD commit (<code>8f4750b</code>) is byte-identical to the head commit of the <i>only</i> Cloudflare Pages deploy that has ever succeeded (GitHub Actions run #6, 2026-08-09) — confirmed by matching commit SHA. Every markup, header-config, and code-level finding in this report is therefore read from the exact bytes Cloudflare currently serves, not inferred from a rendered guess.
GitHub Actions history	All 10 deploy-workflow runs and their job logs were retrieved directly, establishing the deploy pipeline's real success/failure record and root causes with certainty, not speculation.
Live DNS resolution	Not proxied in this sandbox — resolves cleanly to Cloudflare anycast addresses, confirming the domain is active in Cloudflare and consistent with the custom-domain attachment <code>DEPLOY.md</code> describes.
Live web search	Real-time search queries (not a direct fetch to the target) were used for indexing checks and a 20-plus-competitor landscape review, run the same day as this report.

READING THIS REPORT

Any finding whose evidence is source code, CI logs, DNS, or search results is stated as fact. Anywhere this report references contrast ratios, mobile rendering, or Core Web Vitals, it is explicitly labeled as a source-derived *estimate* pending a live re-check — never presented with false certainty.

A FIFTH SOURCE, FOUND AFTER INITIAL DRAFTING

A native Vercel GitHub integration was discovered auto-deploying the Next.js tree on every push — a live pipeline entirely outside the four sources above and outside the repository's own committed CI config, surfaced only via an automated deployment comment this integration posted while this audit's own findings were being committed to the repository. Every reference in this report to that tree's deployment status has been corrected to account for it. The discovery itself is evidence of the same underlying problem the report's architecture-governance findings describe: a deployment surface real enough to build and ship product, existing entirely outside this repository's documentation.

Grading Scale

Every dimension below is graded against the standard a Fortune 500 consumer web property would be held to — not against the informal bar typical of an independent niche-utility tool. The same scale is applied uniformly across all fourteen rows in §4.

GRADE	MEANING
A	Meets or exceeds Fortune 500 standards. No material gaps; this is what "done" looks like.
B	Strong, production-grade execution with limited, low-risk gaps that do not undermine trust or function.
C	Functional, but with material gaps a rigorous review would require closed before calling the work finished.
D	Serious deficiencies that undermine reliability, trust, or discoverability. Not defensible at a Fortune 500 bar.
F	Absent, failing, or actively broken. A foundational capability that does not exist or does not currently work.

Grade Summary

DIMENSION	GRADE	ONE-LINE VERDICT
Visual Design & Brand	C+	Disciplined token system, undercut by a self-labeled "interim shell" with no working promotion path.
UX / Information Architecture	C	Genuinely designed empty states, broken by a mobile keyboard bug and a dead vanity redirect.
Front-end Architecture	C+	The deployed shell is lean and semantic; the ungoverned parallel Next.js stack is the real defect.
Performance & Assets	B-	The live page is ~17.5KB and font-free; the shipped artifact carries 10.4MB of dead weight around it.
Back-end / Data Layer	D+	A-minus code quality; a live, three-week, unmonitored data-currency outage in production.
SEO Foundations	C-	Correct basics (title, canonical, partial OG); no structured data, no robots.txt, no sitemap, no image card.
Indexing & Discoverability	F	Zero results anywhere on the web for the domain, confirmed by live search this session.
Accessibility	C+	Sound semantic baseline; zero focus management on the one interaction the entire product consists of.
Security Headers	B+	Close to best-practice CSP/HSTS/XFO; missing the modern cross-origin isolation trio and CSP reporting.
Privacy & Compliance	B+	Technically-enforced zero-tracking substance; no linkable Privacy Policy page to state it in.
PWA / Mobile Experience	D+	Mobile-aware CSS underneath; zero PWA scaffolding of any kind (manifest, icons, service worker).
Monetization Readiness	C+	Unusually rigorous compliance groundwork; no Privacy Policy and a broken pipeline block every channel.
Content Quality & Depth	F	<200 words live, against ~1,000-1,150 written words sitting unpublished in the same repository.
Overall Grade	D+	See rationale below — not a mechanical average.

WHY OVERALL IS D+, NOT THE ~C- A STRAIGHT AVERAGE WOULD PRODUCE

A simple mean of the fourteen letter grades above lands close to C-/C. This report does not report that number as Overall, because four of the lowest grades — Back-end/Data Layer (D+), Indexing & Discoverability (F), PWA/Mobile (D+), and Content Quality (F) — are not independent polish gaps sitting alongside the others. They share a common root (the broken deploy pipeline, and content that was written but never shipped) and they are *foundational*: a product that cannot reliably serve current data, cannot be found, and has almost nothing to say for itself is not "mostly fine with some gaps" — it is not yet a functioning public product, regardless of how well-built the code underneath it is. Overall Grade is weighted for that reality. The good news, made explicit in Document 2: the two root-cause fixes are small (one credential rotation, one URL update), and the content gap is a porting exercise, not a writing project — this grade is closer to a B than a D once the 30-day plan's first week lands.

5

Dimension-by-Dimension Findings

Each dimension below carries its grade, rationale, what to preserve, and a short pointer to the numbered issues carrying full detail and verbatim fixes in Document 2.

Front-end Architecture

C+

The code that is actually live is well-built for its scope: dependency-free, ~17.5KB total across index.html/app.js/styles.css, semantic HTML with proper landmarks and labels, a correctly deferred `type="module"` script, and a flicker-free CSS-custom-property theme system. That execution quality is undercut by real, source-verified governance failures: a parallel Next.js/Tailwind/shadcn rebuild has had no commits touching it in 34 days, with the migration intent recorded only in a commit message, never in project docs — yet it is not dormant: a native Vercel GitHub integration auto-builds and deploys it on every push, across two separately linked Vercel projects, entirely outside the repository's own committed CI and completely undocumented. Two live, independently-deploying pipelines with no written relationship between them is a governance failure at least as serious as an abandoned branch would have been. On top of that: the repo's one CI type-check gate explicitly excludes the live serverless handler while checking ~1,500+ lines that ship to nobody; the lint script is non-functional; default npm scripts point new contributors at the wrong app entirely; and the split has already produced a manifested, live bug on the domain that matters — the site's own vanity redirects 301 into a route that doesn't exist in the production deploy.

- + ~17.5KB total page weight, zero external JS dependencies, zero web-font requests.
- + app.js loads as a non-render-blocking ES module, correctly placed at the end of body.
- + A single-block, JS-free light/dark theme system driven entirely by `prefers-color-scheme`.
- + Genuinely semantic HTML: real landmarks, true label associations, `aria-live` and `role="alert"` wired correctly.
- + Core subsidy math is pure, dependency-free, isomorphic TypeScript shared verbatim between server and client.

See Document 2, Issues 8-14 for the full architecture-governance findings and verbatim fixes.

Visual Design & Brand

C+

The live `styles.css` shows genuine design-system discipline for a placeholder — a coherent custom-property token set, automatic `prefers-color-scheme` dark mode, a deliberate serif/sans editorial pairing, and light-mode palette values kept hex-identical to the unshipped Next.js design tokens. But the file's own header comment admits it is an "interim shell" standing in for a materially more sophisticated, fully-built design system — licensed type, a signature chart component, a detailed art-direction brief. That system is not blocked from reaching an audience by a broken pipeline: it already auto-deploys to Vercel preview URLs on every push. What it lacks is a decision — nobody has pointed the production domain at it, ported its content into what Cloudflare actually serves, or written down which one is meant to win. A Fortune-500 property would not run an admittedly-provisional brand experience on its real domain while a finished one sits live at an unlinked preview URL with no documented plan to reconcile the two; that governance gap, not the placeholder's craftsmanship, is what caps the grade.

- + Real semantic design tokens via CSS custom properties, not scattered hex values.
- + Dark mode ships today with zero JavaScript and zero flash-of-wrong-theme risk.
- + An intentional serif/sans editorial type pairing achieved with zero webfont requests.
- + Live palette deliberately kept hex-identical to the unshipped design system's tokens.

See Document 2, Issues 14-15 and the theme/typography notes threaded through the architecture section.

UX / Information Architecture

C

The deployed experience gets real things right — the four "unavailable" states are genuinely designed contextual cards rather than toasts, and the semantic/ARIA scaffolding is a sound baseline — but the flow has functional defects a Fortune-500 QA pass would catch immediately: the ages field's `inputmode` locks mobile users onto a keypad with no comma, blocking the exact multi-person households the marketing copy is built around; validation errors leak raw API field keys with no focus management; and the site's own configured navigation aliases 301 into a route that exists only in the undeployed Next.js tree, backed by no custom 404. Layered on a total absence of nav chrome and a methodology explanation that only appears after a user has already entered their income, this is a below-average execution despite a well-thought-out empty-state design underneath it.

- + Four distinct "unavailable" states, each a genuinely designed contextual card with next-step guidance.
- + Every input carries a real label; results use `aria-live`, errors use `role="alert"`.
- + A native, keyboard-accessible "Show the arithmetic" disclosure exposes the full derivation.
- + All interpolated strings pass through an HTML-escaper; currency is formatted consistently.

See Document 2, Issues 22-31 for the full UX/accessibility finding set and verbatim fixes.

Performance & Assets

B-

The page actually served to users is genuinely lean — index.html + styles.css + app.js totals ~17.5KB, a pure system-font stack with zero web-font requests, zero images, and a non-render-blocking module script — structurally pointing to a fast LCP and near-zero CLS, though no live Lighthouse run was possible this session. Against that, the live Cloudflare Pages deploy artifact is 11MB total, and 10.4MB of it (94%) is unreferenced dead weight with zero purpose on the live site; the one image that should be wired in (`og.png`) is not referenced by any tag; and there is no explicit cache policy for the render-path files themselves. A Fortune-500 property would have CI-level asset-usage checks and a documented cache policy preventing all of this.

- + ~17.5KB live page weight with zero web fonts, zero images, zero third-party scripts.
- + Pure system-font stack eliminates FOIT/FOUT and font-swap-driven layout shift entirely.
- + Dependency-free ES module with no render-blocking JS to misconfigure.
- + A strict same-origin CSP structurally blocks a future analytics/ad script from silently adding weight.

See Document 2, Issues 15, 20-21 for the dead-weight, cache, and social-image findings.

Back-end / Data Layer

D+

The code underneath — pure isomorphic subsidy math, integer-cent arithmetic, a typed error taxonomy that already models "data incomplete" as 503 rather than 500, strict input validation, a documented degrade-gracefully ETL design, and 117 passing tests gating deploy — would earn an A- on design merit alone. But this dimension has to grade what is actually running, and what is actually running has not successfully deployed in 22 days: one success in ten CI runs, four consecutive scheduled failures on an expired Cloudflare token, with zero failure alerting anywhere to explain why nobody noticed. A second bug is already queued behind the first: a 404'd CMS data endpoint that will abort the entire ETL and ship a deploy with zero benchmark shards the moment the token is fixed. For a Fortune-500 bar, a live, unmonitored, three-week data-currency failure on a tool whose entire value is a specific dollar figure is disqualifying regardless of how well the code that would fix it reads.

- + Pure, dependency-free, isomorphic core math — server and client can never silently compute different numbers.
- + Integer-cent arithmetic throughout, specifically to prevent rounding drift at the eligibility cliff.
- + A typed error taxonomy correctly distinguishes "bad request" from "service fine, dataset incomplete."
- + A deliberate, documented degrade-gracefully ETL design backed by a build-time synthetic-data guard.
- + Every benchmark quote carries provenance and an explicit verification-status field.

See Document 2, Issues 1-7 — the operational emergency, addressed first in the 30-day plan.

SEO Foundations

C-

Direct inspection of the deployed page confirms title, meta description, canonical, and a partial Open Graph set are present and correctly formed. But `og:image` and all Twitter Card tags are missing despite the needed asset already sitting unused in the deploy artifact, there is no JSON-LD structured data anywhere, and both `robots.txt` and `sitemap.xml` are absent — modest-impact gaps individually, but still baseline hygiene a Fortune-500 property ships by default. No single gap here is independently critical, but the combination — no social preview, no structured data, no crawl-discovery aids — is a real foundational shortfall the correctly-formed basics only partially offset.

- + A distinctive, correctly-formed `<title>`, meta description, and self-referencing canonical.
- + Correct `lang="en"` and viewport meta.
- + The CMS-mandated disclaimer is independently carried in both the page footer and the API's JSON body.

See Document 2, Issues 15-21 for the full SEO/discoverability finding set.

Indexing & Discoverability

F

Live web search confirms zero search-engine visibility: both a site-scoped query and a bare quoted domain query returned no results referencing the domain anywhere on the web. Twenty-two days of zero indexing is not alarming in isolation for a new, backlink-free site, but it is compounded by a site that gives search engines almost nothing to work with — no `robots.txt`, no `sitemap`, no structured data, no image card — at the same moment its deploy pipeline has been broken for 22 consecutive days, preventing the weekly cron from ever landing a freshness signal even after indexing plumbing is added. Layer on a single-page site with no guide content competing against a dozen-plus content-paired rivals, and this is a multi-layered discoverability failure — the kind of gap a Fortune-500 property would not tolerate on baseline technical SEO or CI/CD reliability.

- + Plain, server-delivered static HTML — nothing here is crawler-hostile once discovery infrastructure exists.
- + A social-share image already exists in the deploy artifact; it needs wiring, not creating.
- + Substantial, well-written subject-matter content already exists in the repository, ready to port.

See Document 2, Issues 1, 16, 18-19 — this grade shares its root cause with the deploy outage.

Accessibility

C+

The static shell shows genuine accessibility effort — real landmarks, correct label associations, a decorative SVG correctly hidden from assistive tech, live regions wired into both dynamic areas, an explicit focus-visible ring, and respected reduced-motion — with source-derived contrast estimates clearing WCAG AA for every text color tested. But a full read of the client script shows zero `.focus()` calls, zero `tabindex`, and zero `aria-invalid` / `aria-describedby` anywhere — the dynamic interaction layer, which is the entire product since this is a single-page submit-then-result calculator, has no focus management at all. That primary-flow defect, compounded by a missing skip link and an unlabeled county-choice button group, is what keeps this out of B territory at a Fortune-500 bar.

- + Real semantic landmarks and correct label associations throughout the form.
- + Both dynamic regions wired for assistive tech via `role="alert"` and `aria-live`.
- + An explicit, on-brand `focus-visible` ring, correctly applied to dynamically injected buttons too.
- + Entirely native HTML controls — zero custom-widget reimplementation, zero keyboard-trap risk.
- + Source-derived WCAG contrast estimates clear AA for every text color tested against the page background.

See Document 2, Issues 23-24, 26, 30-31 for the full accessibility finding set.

Security Headers

B+

Verified against the live header configuration, the five configured headers are executed close to best-practice: HSTS carries the full preload-eligible combination; the CSP has no `unsafe-inline` / `unsafe-eval` and matches a page confirmed to have zero inline scripts or style attributes, so the strict policy is actually enforceable rather than aspirational; X-Frame-Options backstops CSP's frame-ancestors; and no CORS header is present, so the same-origin-only API carries no misconfiguration risk. What keeps this below A-range: the modern cross-origin isolation trio (COOP, COEP, CORP) is completely absent, the CSP has no reporting endpoint so a future policy break fails silently, and Permissions-Policy locks down only three of roughly twenty-five gatable features. These are hardening and observability gaps, not live exploits.

- + HSTS configured correctly on every axis at once — the exact combination preload-list submission requires.
- + A CSP with no unsafe directives that genuinely matches the deployed markup's needs.
- + X-Frame-Options: DENY and CSP frame-ancestors: none both set, covering modern and legacy clients alike.
- + No CORS header anywhere — the API is same-origin-only by construction, not by oversight.
- + The full header set applies uniformly across every route — no path carries a weaker posture than another.

See Document 2, Issues 32-35 for the isolation-header and reporting-endpoint findings.

Privacy & Compliance

B+

This is the strongest dimension of the site by a wide margin: zero cookies and zero tracking are not merely claimed but technically enforced by a same-origin-only CSP that would block any accidentally-reintroduced third-party script from ever executing. The non-Marketplace disclaimer is duplicated at the API layer, so even a programmatic caller who never loads the HTML still receives it, and the project's self-imposed compliance rules cite specific federal regulations with genuine, source-confirmed reasoning rather than boilerplate. Set against a true Fortune-500 bar, though, the total absence of any linkable Privacy Policy or Terms page, of any operator identification, and of disclosure that the hosting layer itself necessarily processes connection metadata are checklist-level gaps that would block a launch review regardless of how little data the application layer actually touches. The substance is excellent; the packaging is missing.

- + No cookies, no analytics, no tracking script anywhere — confirmed by full source read, not just a footer claim.
- + The "no tracking" posture is technically enforced by the CSP, not merely promised.
- + Permissions-Policy explicitly blocks FLoC/Topics-style tracking at the browser-API level.
- + The non-Marketplace disclaimer is compliance-by-construction: identical text in both HTML and API response.
- + Self-imposed build rules cite specific CFR sections with genuine, source-confirmed reasoning.
- + Correctly omits a cookie-consent banner rather than adding one as theater, since no cookies are set.

See Document 2, Issues 36-38 for the policy-page and disclosure findings.

PWA / Mobile Experience

D+

Direct inspection confirms zero PWA scaffolding: no manifest anywhere in the repository, no icon set beyond a single inline 32×32 SVG favicon, no theme-color meta, and no service worker. The site fails Chrome/Edge's installability criteria outright and has zero offline resilience, even though the existing immutable one-year cache policy on benchmark data would have made offline support unusually cheap to add. The one genuine strength is solid mobile-responsive CSS — fluid grids, `clamp()`-based type, and a deliberate iOS zoom-on-focus mitigation — real signals of mobile-aware authorship, though unconfirmed against a live rendered screenshot. Held to a Fortune-500 bar, which expects baseline PWA hygiene even on properties that aren't full installable apps, a site clearing none of those checklist items lands well below bar.

- + Fluid CSS grid layouts for both the form and results, with no media-query breakpoints needed.
- + Both major headline sizes use `clamp()` for genuine fluid type scaling.
- + A deliberate iOS Safari zoom-on-focus mitigation (inputs inherit the 17px body font).
- + The correct, unrestricted viewport meta tag — pinch-zoom remains available.
- + An already same-origin-strict CSP means a manifest and service worker are purely additive, no relaxation needed.

See Document 2, Issues 39-41 for the manifest, icon, and service-worker findings.

Monetization Readiness

C+

The team has uncommon governance groundwork for this project stage: explicit non-negotiable rules and a disclaimer-duplication pattern are a real compliance-by-construction precedent that could extend directly to future ad/affiliate/broker disclosures. But the architecture is not yet built to receive monetization safely — there is no Privacy Policy at all, a near-universal prerequisite for AdSense, affiliate programs, and broker-referral partnerships — and the deploy pipeline has failed for 22 consecutive days, so even a fully-built monetization feature cannot currently reach production. These are concrete, currently-absent pieces rather than abstract risks.

- + Explicit, well-reasoned non-negotiable monetization rules — proactive governance rarely seen at this stage.
- + The non-Marketplace disclaimer pattern is a reusable template any future disclosure could extend.
- + Zero tracking, zero cookies, zero PII today — no legacy dark-pattern debt to unwind before monetizing cleanly.
- + A strictly typed, 117-test-covered backend means a future referral/lead-gen endpoint is low regression risk.

See Document 2, Issues 36, 44-45 and the full Monetization & Affiliate Map in Document 2.

Content Quality, Depth & Topical Authority

F

The entire live content footprint is one page of under 200 words with only two headings — no blog, no FAQ, no guide, no live methodology page. This is a stark deficit against named competitors that pair a calculator with dedicated guide content. The notable part, also verified directly, is that substantial subject-matter writing already exists in-repo — roughly 1,000-1,150 words of genuine explanatory prose split across README.md and an unbuilt methodology page — but none of it is accessible to users or search engines. For a Fortune-500 content bar, real topical expertise that was written and then left entirely locked inside developer docs is close to the worst outcome available: the capability is proven, and none of it is doing its job.

- + The disclaimer and privacy copy that does ship is accurate and precisely worded, not generic boilerplate.
- + Unusually rigorous, well-written subject-matter and compliance reasoning already exists in README.md.
- + A largely complete, ready-to-port methodology page already exists — closing the gap is a porting exercise.
- + What little content ships is dense and correct rather than padded with filler.

See Document 2, Issue 42 and the full 30-Day Content Plan.

6

Strengths to Preserve

A rewrite driven by this report's findings should not touch the following — they are the site's genuine competitive assets and should be carried forward unchanged into every future revision.

Zero-PII architecture, technically enforced

No cookies, no logging, no analytics — enforced by a same-origin CSP, not just a promise. This is a real, defensible differentiator against a competitive field where even "no signup" competitors quietly run ads and affiliate tracking behind that claim.

Isomorphic, pure subsidy engine

The same TypeScript core runs in the Worker, in Node, and in-browser. Server and client can never silently disagree on a number — a correctness guarantee most calculators in this space do not have.

Fail-loudly data philosophy

Missing or unverified data returns a typed reason, never a fabricated estimate. Given repayment-cap repeal makes a wrong number the user's liability, this is the single most important design decision in the codebase.

Provenance as a first-class type

Every benchmark and every result carries its source and verification status through to the API response. This is the natural foundation for the trust/methodology content the 30-day plan recommends shipping.

Best-practice security headers

The CSP, HSTS, and frame-protection configuration is close to exemplary and should be extended, not replaced, as the isolation-header and reporting-endpoint fixes in Document 2 land.

Regulation-literate compliance posture

Self-imposed rules citing specific CFR sections, adopted voluntarily rather than because a regulator demanded it. This is a portfolio-wide model, not just a site-specific asset.

Technical Stack, Identified Precisely

LAYER	WHAT IS ACTUALLY DEPLOYED
Hosting / edge	Cloudflare Pages, project <code>subsidy-dropoff</code> ; DNS resolves to Cloudflare anycast addresses.
Deployed front end	Static HTML/CSS/vanilla ES module — no framework, no bundler, no build step (<code>public/index.html</code> + <code>app.js</code> + <code>styles.css</code>).
Serverless API	Cloudflare Pages Functions (<code>functions/api/[[route]].ts</code>), a WHATWG Request/Response handler reading static JSON "shards" via the ASSETS binding.
Core logic	Pure, dependency-free TypeScript (<code>src/core</code>) — isomorphic across Worker, Node, and browser.
Data pipeline	A GitHub Actions-run ETL (<code>src/etl</code>) pulling CMS Marketplace Public Use Files and Socrata open-data endpoints at deploy time; no database, no runtime CMS calls.
Testing	Vitest, 117 tests across four suites, gating every deploy in CI.
CI/CD	GitHub Actions (<code>.github/workflows/deploy.yml</code>) → <code>wrangler pages deploy</code> , triggered on push, weekly cron, and manual dispatch.
Not on the production domain	A parallel Next.js 16 (App Router) + Tailwind v4 + shadcn-style rebuild (<code>app/</code> , <code>components/</code>), using next/font, Recharts, and a considerably richer Metadata block. No commits in 34 days, and not wired into the repository's own committed CI — but confirmed auto-building and deploying via a native Vercel GitHub integration (two linked projects) to preview URLs on every push. DNS confirms Cloudflare, not Vercel, serves the production apex domain.

Competitive Landscape (Condensed)

Live search this session surfaced **20+ active competitors** in the "ACA subsidy cliff" niche — the 2026 expiration of enhanced premium tax credits triggered a genuine content gold rush in this space. Three tiers emerged, summarized below; the full 20-competitor table with positioning, content strategy, and monetization detail per competitor is in Document 2.

TIER	COMPOSITION	WHAT THEY HAVE THAT SUBSIDY DROPOFF DOESN'T
Legacy publishers & lead-gen brokerages	healthinsurance.org, ValuePenguin (LendingTree), healthcareinsider.com, carrier/brokerage tools	Domain authority, traffic, and (for the brokerage tools) direct commercial bias — the calculator is subordinate to an ads/lead-gen business.
Programmatic-SEO tool network	acacalc.com, taxcliffs.co, quantcalc.app, nationaltaxtools.com, acasubsidyguide.com, taxpayers.net, and a dozen more	Nearly all pair a calculator with a guide, a state-page cluster, or MAGI-reduction strategy content — the content layer Subsidy Dropoff currently has none of. QuantCalc already contests the exact "privacy-first, client-side" claim.
Nonprofit / policy-grade tools	KFF, PolicyEngine's open-source ACA-Calc, CBPP's Beyond the Basics, the IRS estimator	Genuinely neutral like Subsidy Dropoff, but not "cliff"-branded or SEO-optimized for the 2026 moment, and running dated interactive-tool UX — the one tier Subsidy Dropoff's engineering already beats.

THE UNCONTESTED POSITION

The combination "zero PII *and* zero ads *and* zero affiliate links" is, per this session's research, not currently claimed explicitly by any competitor — several market "no signup" while quietly running ad/affiliate monetization behind it. This is a real, still-available differentiator, but only once it is stated on the site itself and backed by enough content depth to be found.

Portfolio-Context Notes

Subsidy Dropoff sits at the strict end of the portfolio's regulatory-sensitivity spectrum — closer in monetization posture to a nonprofit policy tool than to the recipes/food or sports-analytics properties, which carry no licensing risk and can run heavier affiliate and display monetization from day one. That is the correct posture for this site, not a deficiency: trust and topical authority have to be built before any revenue layer is added, and revenue must stay strictly non-contingent and off the calculator surface itself, per the project's own README rules.

Engineering culture worth propagating

The fail-loudly, provenance-first, zero-PII-by-construction design pattern used here is stronger than what a typical niche utility site ships. It is a reasonable template for the other "health tools" bucket sites in the portfolio, and a useful contrast point for the internal ops tools, which face lower external trust requirements but could still borrow the typed-error/provenance discipline.

Cross-promotion opportunity, done carefully

A lightweight, tracking-free "more free tools" footer module linking to genuinely relevant sibling health-tool properties is a low-cost distribution channel for a site with zero current backlinks — provided it never links anything insurance-sales-flavored, which would blur the "not a broker" line the whole site depends on.

A brand asset for the portfolio, not just this site

Once shipped, the explicit "zero PII, zero ads, zero affiliate" claim is a differentiated trust signal the wider portfolio can point to — "the strict-privacy sibling site" — as a counterweight to properties that do run heavier monetization.

This is a launch-readiness problem, not a rebuild

Every dimension graded D or F in this report shares one of two root causes — the broken deploy pipeline, or unpublished content that already exists. Fixing both is days of work, not a redesign, and should be treated as before any further feature work across the portfolio's other health-tool properties.

Subsidy Dropoff — Website & Product Audit · subsidydropoff.com · August 31, 2026
Companion document: *Numbered Issues, Verbatim Fixes & 30-Day Plan*